Relatório de Evidências Técnicas - Clube Aurora

Nome do Aluno(a): Diego Renato dos Santos

Turma: DevSecOps 1746

Nível Escolhido: [ ] Nível 2 (Mista) | [x] Nível 3 (Técnica)

Link do Repositório / Fork no GitHub: https://github.com/diegosantosrd/devsecops-1746-projeto-final *(Caso o repositório seja privado, certifique-se de adicionar a professora como colaboradora para avaliação)*

Link do Pull Request Principal: https://github.com/diegosantosrd/devsecops-1746-projeto-final/pull/1

---

1. Evidência do Pipeline Inicial (Antes das Correções)

Cole aqui o print ou log demonstrando o pipeline falhando no estado inicial:

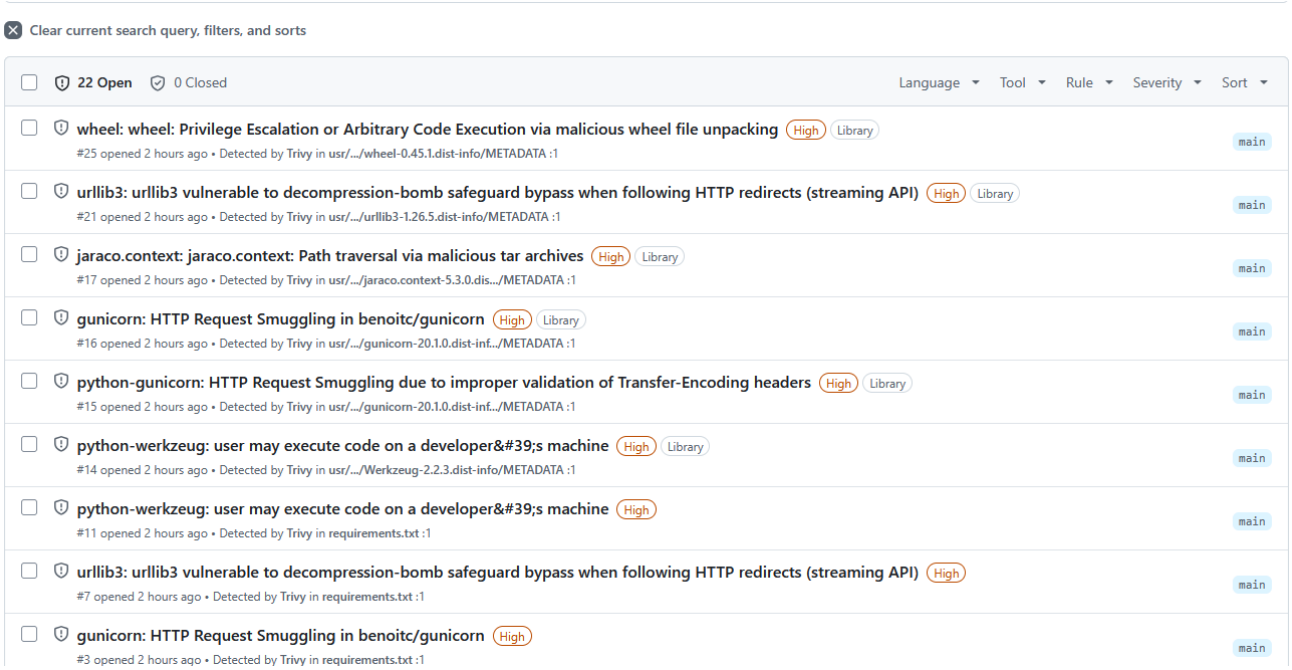
- **Screenshot da Aba Actions (Pipeline com steps vermelhos):**

https://github.com/diegosantosrd/devsecops-1746-projeto-final/actions/runs/40680788734

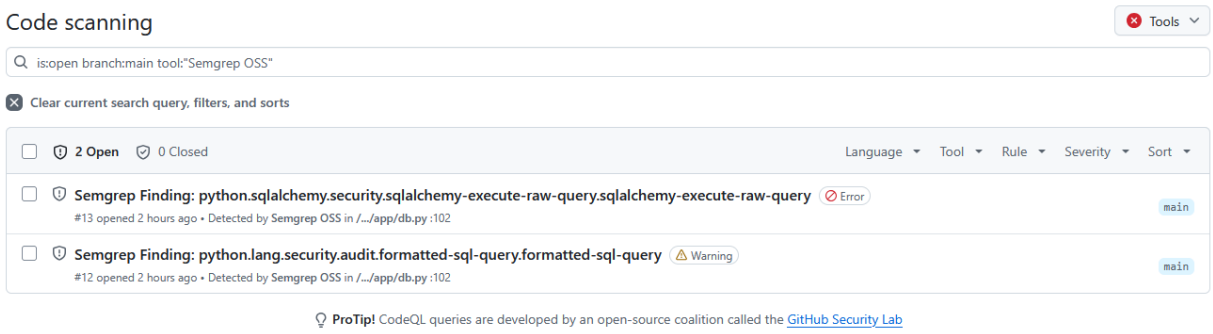
- **Principais falhas apontadas pelas ferramentas:**
- Hadolint:



-
- Trivy FS:



-
- Semgrep:



-

---

2. Resumo das Correções Implementadas

Descreva brevemente como você corrigiu cada achado sob seu escopo técnico:

Achado	Arquivo Modificado	Resumo da Alteração Realizada
F1: Segredos	`.gitignore` / `.env`	Removi .env do git, e adicionei ao conteúdo do .gitignore; adicionei .env.example
F2: SCA	`requirements.txt`	Alterei as versões das dependências no arquivo requirements.txt , colocando valores fixos.
F3: SAST *(Nível 3)*	`app/db.py`	Alterei para parâmetros ? na consulta em vez de concatenação de strings.
F4: Hardening	`Dockerfile`	Criei imagem de build e de runtime no

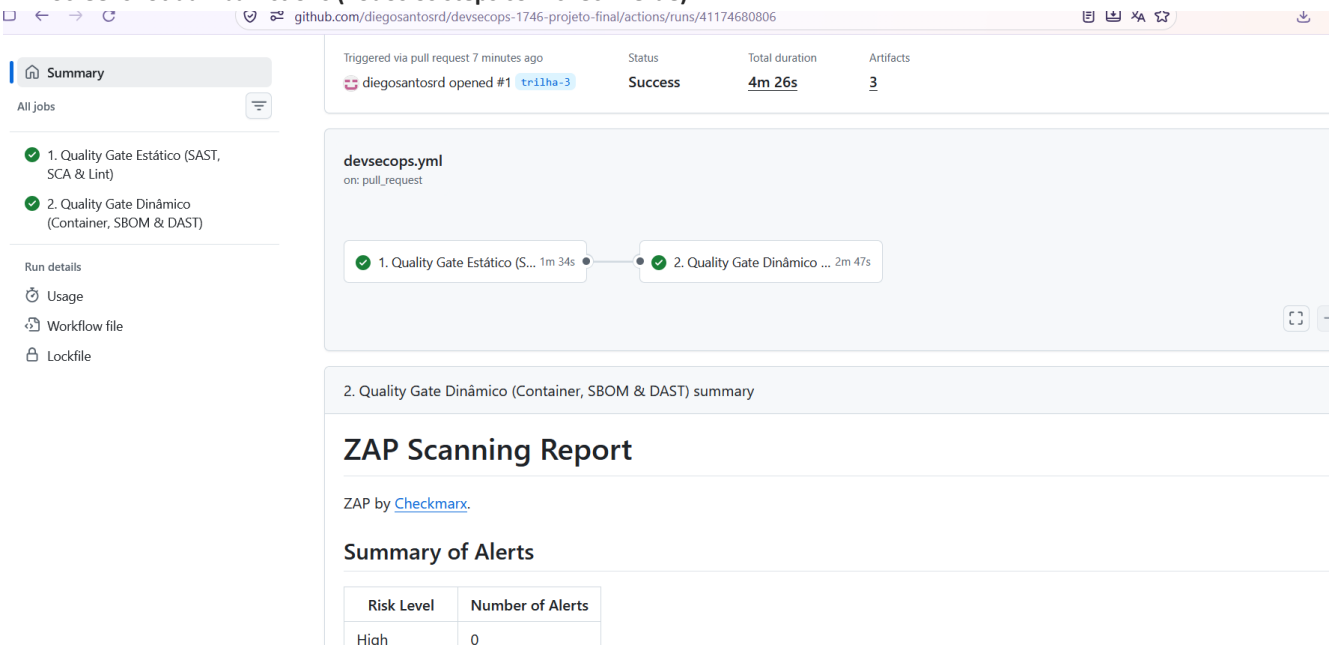
		Dockerfile. Feita atualização da setuptools.
F5: DAST *(Nível 3)*	`app/main.py` e `app/__init__.py`	Adicionei hook @app.after_request em __init.py__ para adicionar os cabeçalhos necessários. **Observação: também alterei o rules.tsv do OWASP ZAP para não falhar nos casos de alertas de nível informational.**
F6: Menor Privilégio *(Nível 3)*	`app/db.py` / `app/main.py`	Coloquei que novos usuários tem permissão de “client” e não de “admin” no banco; fiz com que alteração de usuários somente possa ser feita por usuários com a role de “admin”.
F7: IaC *(Nível 3)*	`docker-compose.yml`	Removi porta e volume socket desnecessários e inseguros; acrescentei volume para o banco sqlite.

---

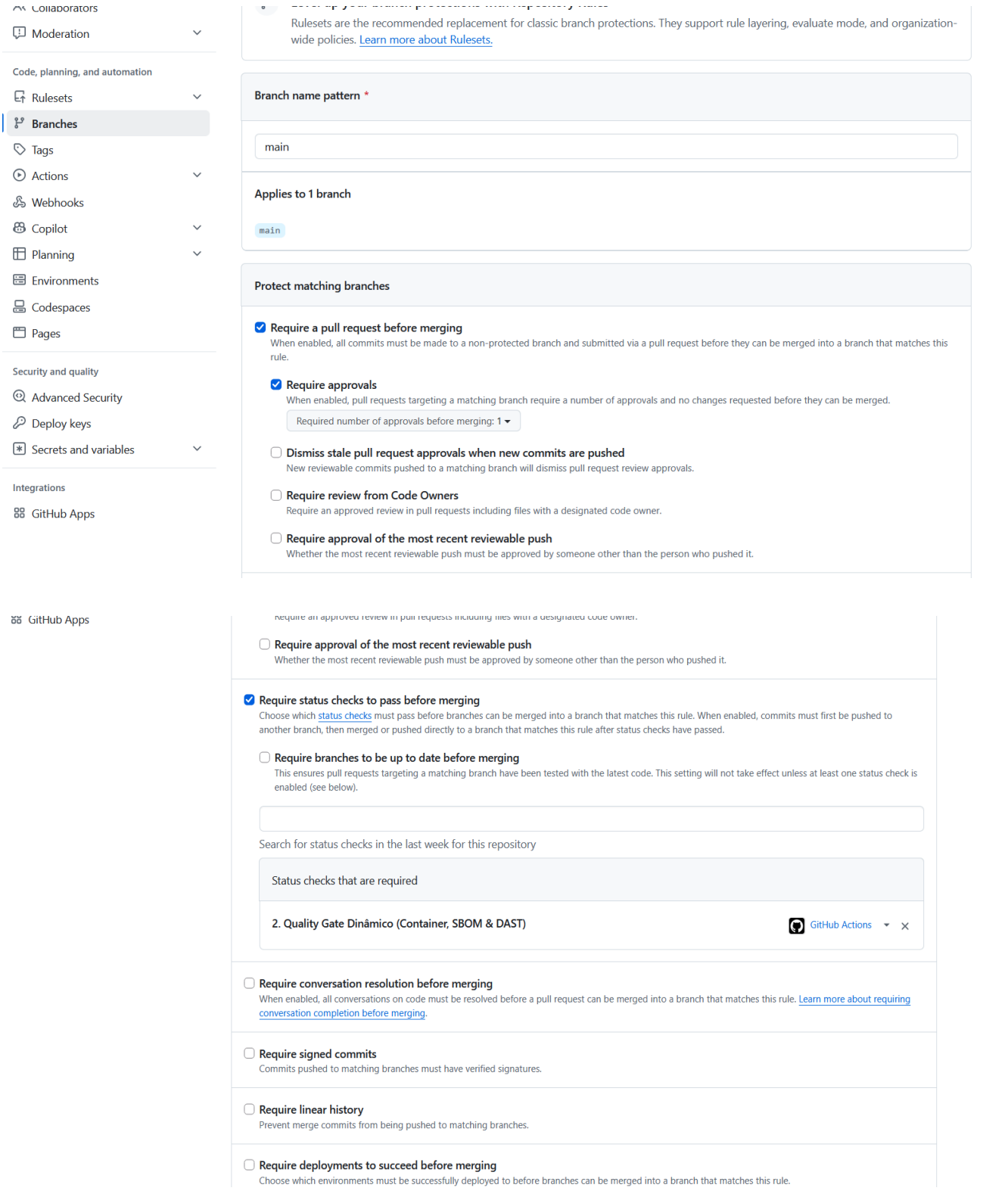
3. Evidência do Pipeline Final (Após as Correções)

Cole aqui a comprovação de que o pipeline foi executado com sucesso:

- **Screenshot da Aba Actions (Todos os steps com check verde):**



- **Link direto para a execução bem-sucedida do Actions:** https://github.com/diegosantosrd/devsecops-1746-projeto-final/actions/runs/41174680806
- **Proteção da Branch Main:**



---

4. (Opcional - Trilha C) Justificativa de Aceitação de Risco (`.trivyignore`)

Se houver alguma vulnerabilidade de severidade MEDIUM mantida:

- **CVE ou ID:** [...]

- **Justificativa de negócio e prazo para correção:** [...]